

Diamond Hands Protocol (DHP) — Self-Audit Report

Self-Audit & RFP Findings

Date: 2026-09-05

Auditor: Spock via Hermes Agent (Claude)

Scope: DHPImplementation.sol, DHPFactory.sol, DHPFeeCollector.sol, IDHPVault.sol (~900 LOC)

Tests: 54 of 54 passing across 3 test suites

Severity Scale:

- **Critical:** Loss of user funds or contract unusable
- **High:** Significant loss of funds or DoS
- **Medium:** Loss of small amounts or griefing
- **Low:** Code smell or gas inefficiency
- **Informational:** Best-practice deviations

Critical Findings (2)

C-1: mint() has same _distributeTax ordering bug as deposit()

The fix applied to deposit() (run _distributeTax BEFORE _accrueDividend) was not applied to mint(). Current code: _accrueDividend THEN _mint THEN _distributeTax. Expected: _distributeTax THEN _accrueDividend THEN _mint. This causes over-minting (~10%) and dilutes existing shareholders.

C-2: BURN_SINK = 0x...dEaD reverts on tokens with blacklist hooks

USDT, USDC, BUSD explicitly blacklist 0x...dEaD. _distributeTax reverts on every deposit/withdraw. The vault is DoSed against all major stablecoins.

High Findings (4)

H-1: createVault permissionless + unbounded

Anyone can call createVault() for any ERC-20, bloating the allVaults array. A griever with 1 ETH can create ~6500 vaults. Economic guard needed.

H-2: mint()/deposit() semantic mismatch

mint() over-mints by ~10% vs deposit(). Users paying at the “wrong” rate gives extra value to new depositors at the expense of existing holders. Fixed by mirroring deposit() order.

H-3: First-deposit “squat” inflation attack

1-wei squat + next depositor loses net deposit. 1-wei squat gains 50% of next depositor’s deposit value via the dividend pool. Mitigation: minimum initial deposit / virtual offset.

H-4: Direct-donation attack on FeeCollector

Anyone can transfer tokens directly to FeeCollector, inflating pendingBalance. Attacker tips, DAO gains. Document as “tip jar” or restrict sweep.

Medium Findings (7)

- Anti-FOT check fails for legitimate tokens with hooks (M-1)
- sandwich attacks on dividend claims (M-2)
- pause() dead code given factory architecture (M-4)

- `_update` hook gases on 0-value transfers (M-3)
- `_accrueDividend` divides by `totalSupply=0` guard (M-6)
- FeeCollector pendingBalance inflatable (M-6)
- `pause()` dead code (M-7)
- `Math.mulDiv` gas-heavy (M-7)

Informational (6)

- Deposit/Withdraw events declared in interface AND contract (I-1)
- Agrees with README on 0.5% of every tax (I-2)
- Architecture: factory renounced post-launch (I-3)
- Smoke-test confirmed dividend math (350 SPX payout) (I-6)

Summary Table

• **Critical:** 2 | **High:** 4 | **Medium:** 7 | **Low:** 5 | **Informational:** 6

Top Priorities to Fix Before External Audit

1. Fix `mint()` ordering (mirror `deposit()` `_distributeTax` → `_accrueDividend` → `_mint`)
2. Replace `BURN_SINK` with lock-in-vault or per-token config
3. Mitigate first-deposit inflation attack (dead share / virtual offset)
4. Add economic guard on `createVault` (fee, whitelist, or DAO permission)

Summary

• 2 Critical | 4 High | 7 Medium | 5 Low | 6 Informational

All 54 tests pass. 3 contracts on Base Sepolia Sourcify-verified.

Self-audit at `SELF_AUDIT.md`. RFP at `RFP_AUDIT.md` (targets \$15-30K tier-2 firms).

Next Steps:

1. Fix `mint()` ordering (mirror `deposit()` `_distributeTax` → `_accrueDividend` → `_mint`)
2. Replace `BURN_SINK` with lock-in-vault
3. Mitigate first-deposit inflation attack
4. Add economic guard on `createVault`
5. Re-run tests, re-deploy, send RFP to tier-2 auditors